Governing AI Agents in Production: Lessons from building Risk Trainer at zero cost

Human governance, multi-vendor AI workflows, and cloud controls.

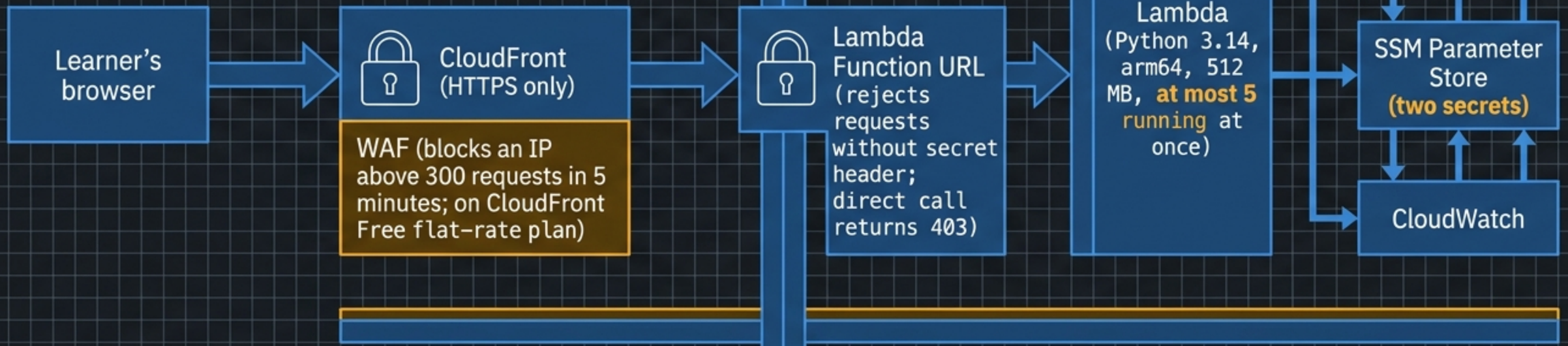


Target $0.00 monthly spend | 376 automated tests | 98.38% coverage.

Gemini Notebook

The Crucible: Risk Trainer

Free, **no-login web app** teaching security **risk prioritization**. 5 findings, capacity to fix 2. Choose **avoid**, mitigate, transfer, or accept, and for **accept**, **who signs off**. Deterministic scoring; no AI calls.

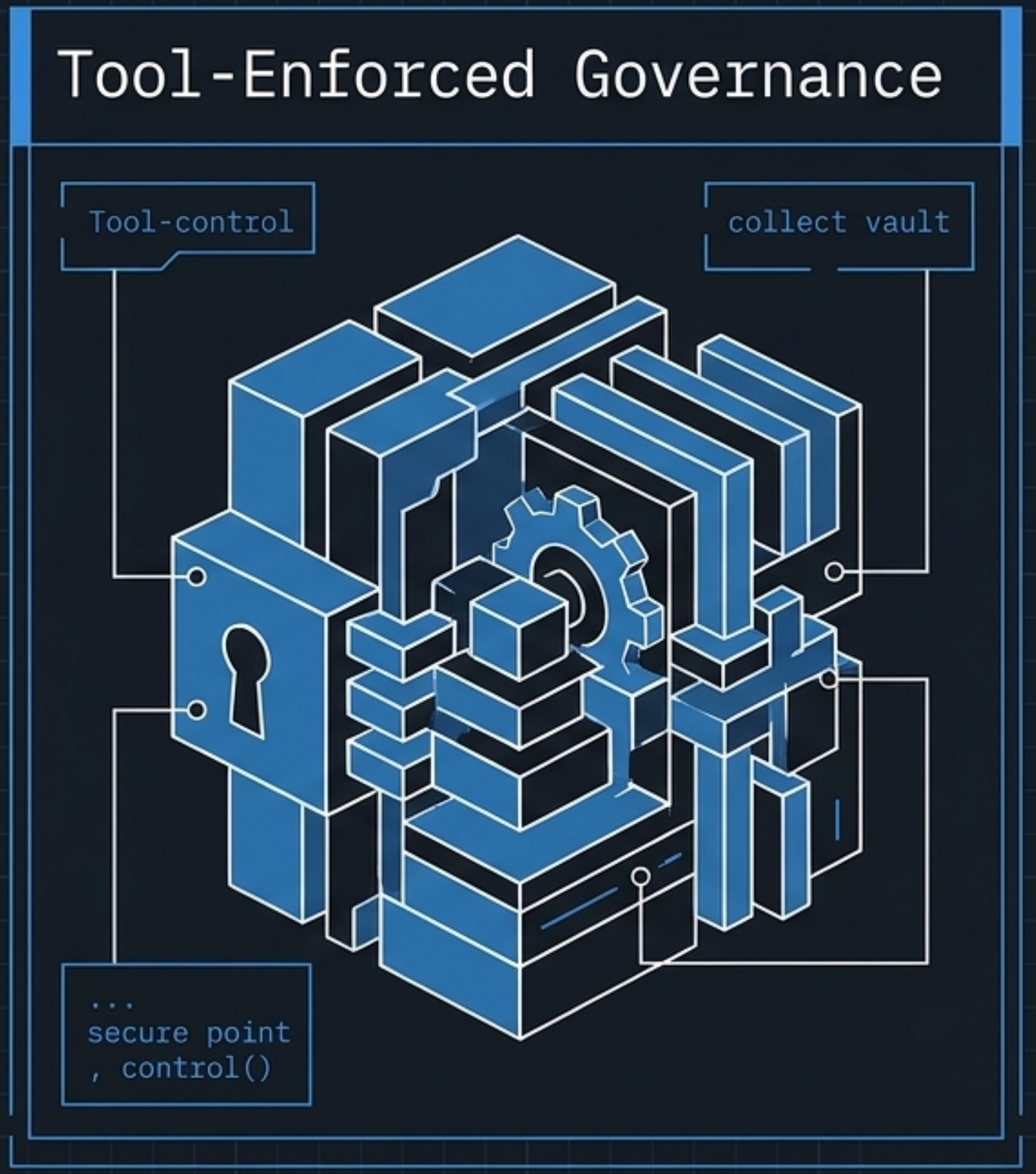


Gemini Notebook

The Illusion vs. the Reality of AI Development

Instruction-Based Trust

Natural language instructions are not controls. Prompt guidance does not constrain tools or command execution.



Gemini Notebook

The Multi-Vendor Separation of Duties Matrix

Specification:	Claude (writes text only; no repo or cloud access; owner reviews and decides every requirement and scenario)
Spec challenge:	ChatGPT (free) (reads spec only; owner decided all 15 findings: 13 accepted, 1 rejected in part, 1 owner decision)
Content fact-check:	Perplexity (free) (reads scenarios only; owner checks citations against NIST SP 800-39, NIST SP 800-30 Rev. 1, ISC2 CISSP outline, then runs rt approve)
Build:	Claude Code (edits code on owner's Mac; cannot push to main, merge, run terraform apply, create secrets, or approve content; owner approves every plan before changes)
Pull request review:	Read-only Claude review agent plus CodeQL, Semgrep, checkov, gitleaks, pip-audit (review agent can only post inline comments; required checks must pass and every conversation resolved before merge; owner merges)
Deploy:	GitHub Actions signing in via OIDC (plan role on main; deploy role only in protected prod environment; owner reads Terraform plan and approves prod deploy)

The entity writing the code never reviews, merges or deploys it. CodeQL and Semgrep add checks from outside the AI vendor.

Gemini Notebook

Incident Anatomy: 6 Oct 2026

During infrastructure work, Claude Code ran broad cleanup command:

```
rm -rf infra/*/.terraform
```

What was deleted:

`local .terraform` working folder inside `infra/bootstrap/` on the owner's Mac (a cache of downloaded provider plugins and state pointer, not code).

What was untouched:

`Terraform` code, S3 `state`, and AWS.

Resolution:

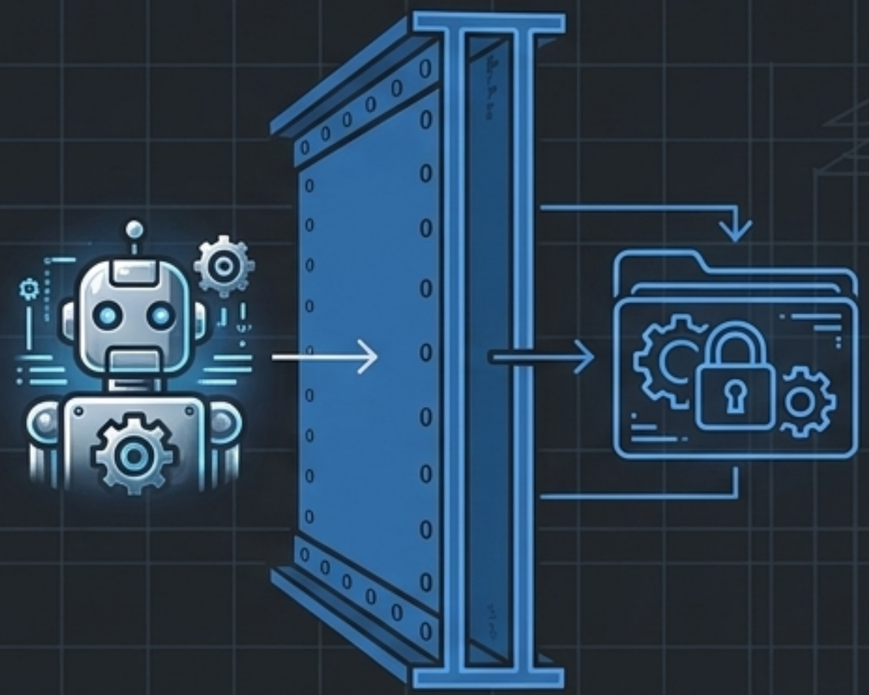
The agent reported the deletion itself. Owner re-initialized and `Terraform` showed no changes.

Gemini Notebook

Moving from Instructions to Tool-Enforced Constraints

.claude/settings.json

```
{
  "deny_rules": [
    "Edit(/infra/bootstrap/**)",
    "Bash(rm -rf *)"
  ]
}
```

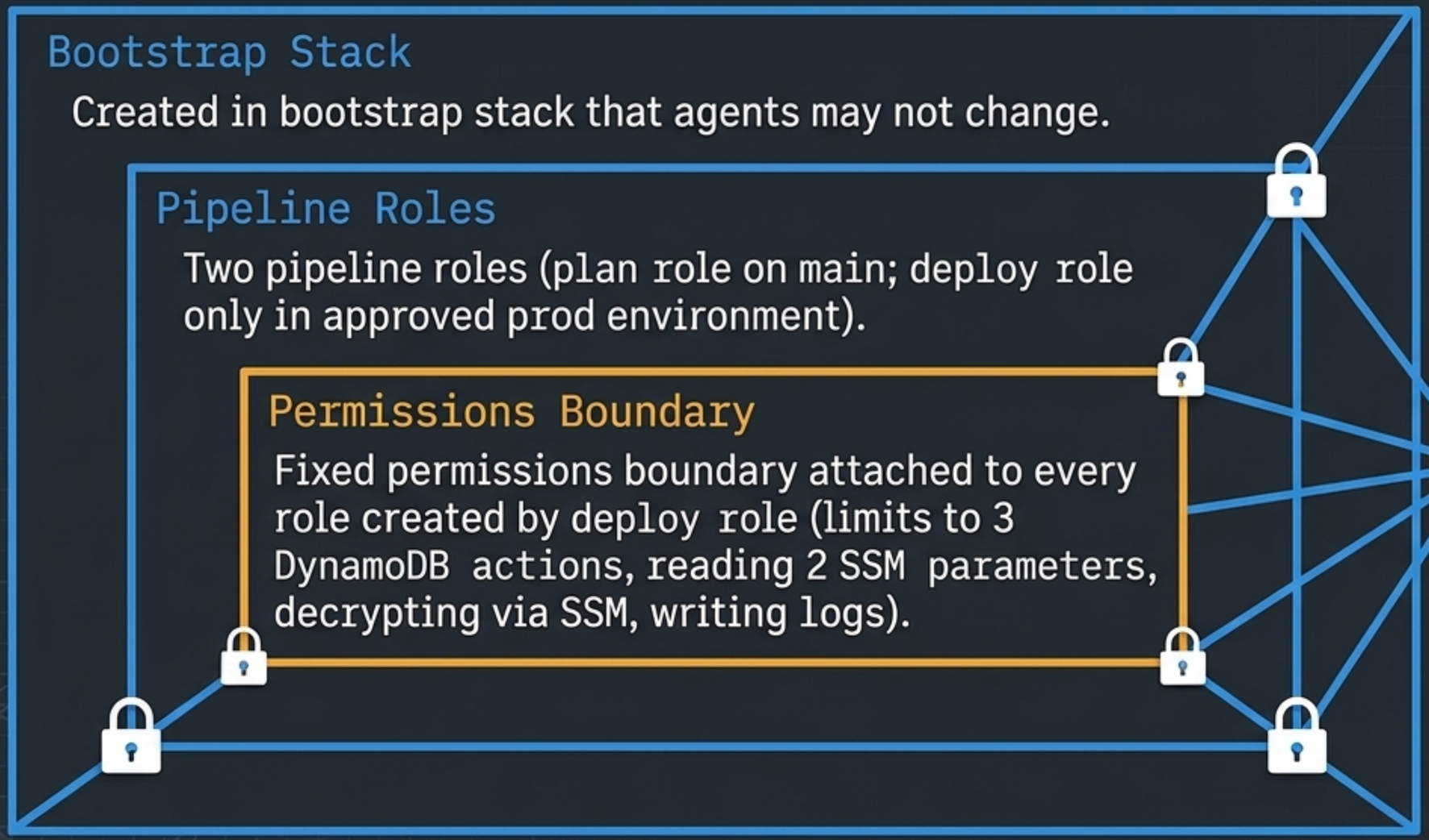


The agent can’t override these through its normal tools. Because they match command text, they’re a guardrail, not a sandbox.

When the bootstrap later needed a fix, the agent wrote a patch and the human applied it.

Gemini Notebook

The Pipeline Can’t Widen Its Own Access



Explicit denies stop removing boundary, attaching managed policies, changing trust policies, or changing pipeline roles/boundary/OIDC provider.

Terraform test removes each guardrail in turn and fails every time.

Gemini Notebook

Designing the Human Gate (CI/CD)

Pull Request

Required checks must pass plus every conversation resolved, then the owner merges.

Review agent can only post comments.

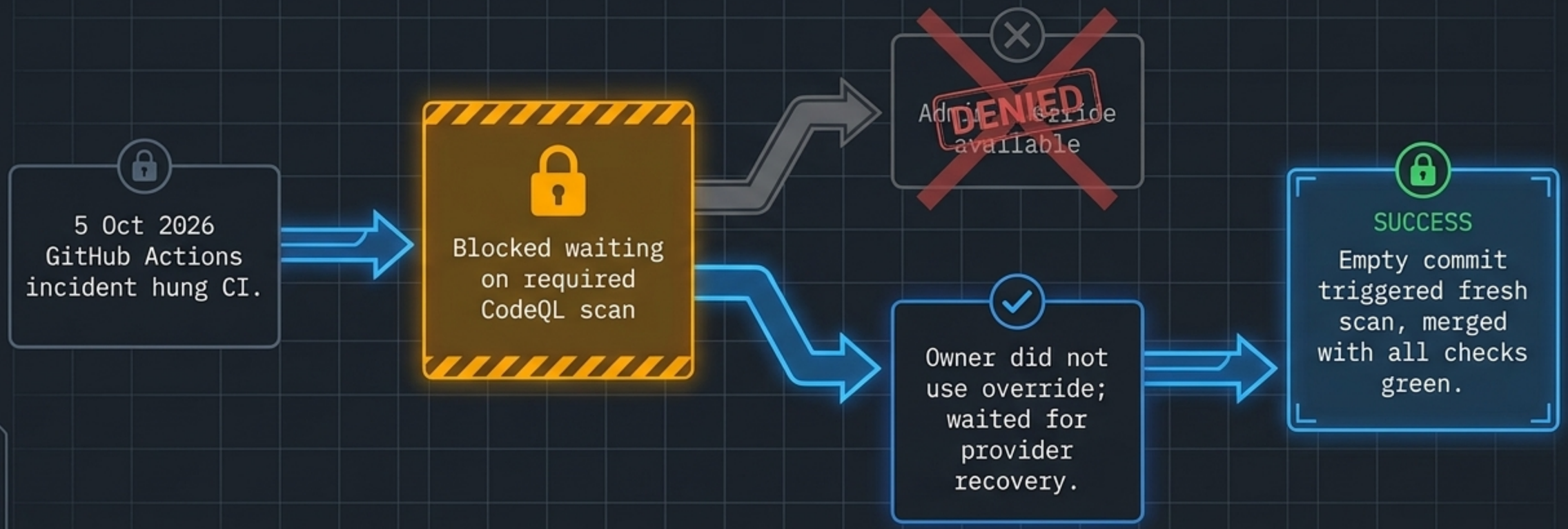


Deploy

Owner reads the `Terraform plan` and approves the `prod` environment.

Gemini Notebook

Holding the Line Under Pressure



Gemini Notebook

Identity & Access: Debugging OIDC Federation

Expected by the trust policy:
`repo:dustenatx/risk-trainer:ref:refs/heads/main`

Sent by GitHub:
`repo:dustenatx@54679392/risk-trainer@1398551921:ref:refs/heads/main`

Immutable numeric IDs cannot be taken over if a name is re-registered.

Gemini Notebook

Cost Architecture is Governance

Hard ceilings

Lambda reserved concurrency 5; DynamoDB provisioned at 25 RCU / 25 WCU with auto-scaling off (throttles instead of billing); CloudFront Free flat-rate plan includes WAF and DDoS with no overage charges.

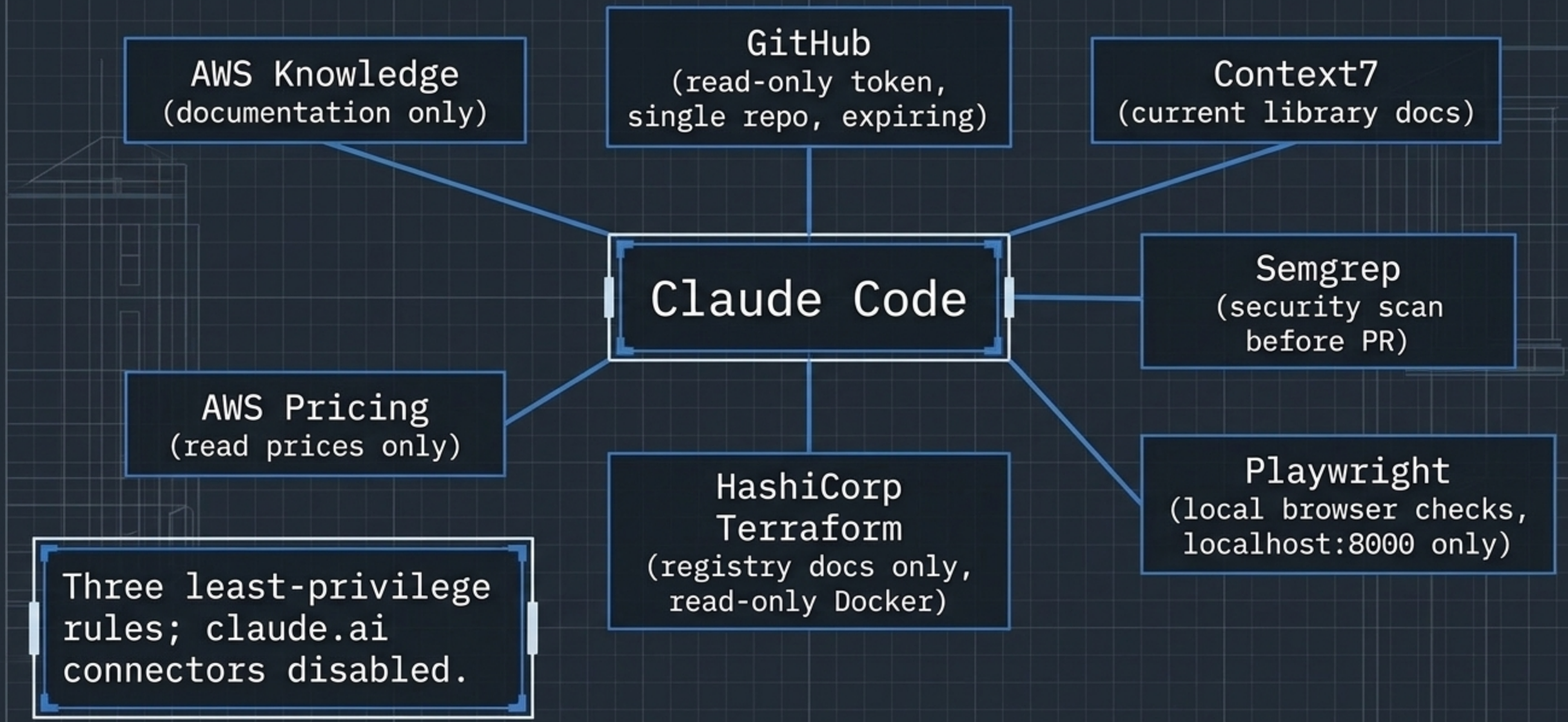
Soft alerts

AWS Budgets at $0.01 and $1/month detect spend after it happens.

Result: traffic flood causes throttling, not a large bill.

Gemini Notebook

Scoping the Model Context Protocol



Gemini Notebook

MCP in the Product: Roadmap

PLANNED. Neither exists today; no ‘enabled’ or ‘running’ status.

v1.1 (next): authoring MCP server

5 tools (`get_schema`, `list_scenarios`, `validate_scenario`, `score_answers`, `save_draft`).

Writes only to `content/drafts/`.

Missing `approve` tool as the point so publishing stays human.

v1.2 (stretch): learner /mcp connector

Public read-only `/mcp` endpoint on Lambda; learners add custom connector in their own Claude so their subscription pays for AI coaching.

Gemini Notebook

Honest Trade-offs

SECRET STORAGE COMPROMISE

Origin secret stored in encrypted `Terraform` state file.

DEPLOYMENT CONSISTENCY TRADE-OFF

Apply job rebuilds and plans again rather than applying exact reviewed plan (reproducible package build).

TLS VERSION ACCEPTANCE

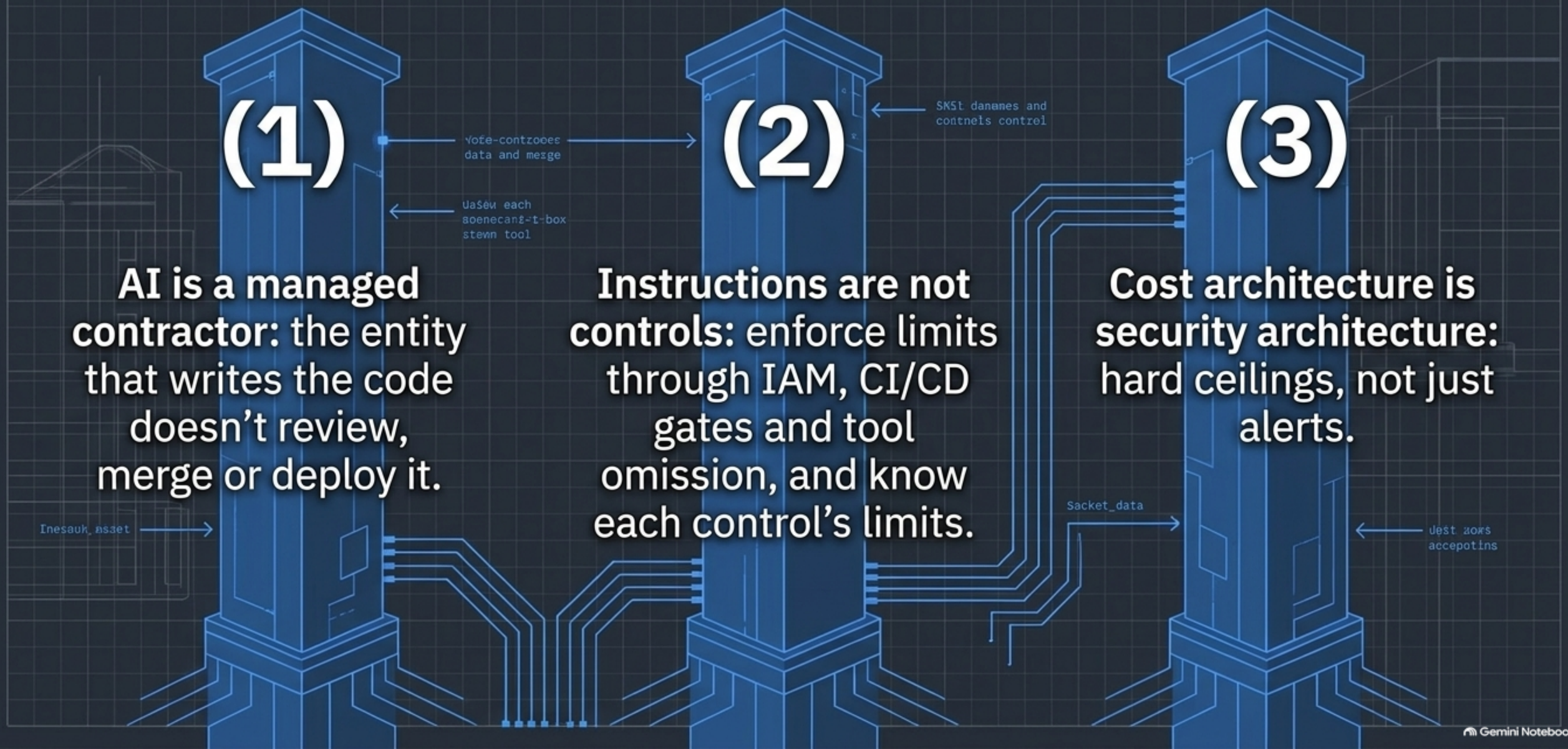
Default `CloudFront` certificate allows TLS 1.0 (custom domain costs money).

SECURITY GUARDRAIL LIMITATION

`Claude Code` deny rules match command text (guardrail, not sandbox).

Gemini Notebook

The New Blueprint



Gemini Notebook